

CyberShip Security Awareness Worksheet

Newcastle University · Durham University · CyberNorth · Innovate UK

This document serves as a baseline audit of your organisation's current security posture.

How to use this plan:

1. **Audit (The Baseline):** Read the sections below. **Tick** a box *only* if that measure is currently **fully active** across your *entire* organisation to the best of your knowledge.
 2. **Prioritise (The Strategy):** Review the unticked boxes. **Circle** the **three** specific actions you will explore further within the next 90 days.
 3. **Execute:** Use this document to help spark discussions in your organisation.
-

1. Identity & Access Management

- ☐ **MFA (Multi-Factor Authentication)** is enforced on *all* email, cloud storage, and social media accounts.
- ☐ **Incident Reporting:** A clear mechanism exists for staff to report suspicious emails immediately (e.g., a "Report Phishing" button).
- ☐ **Payment Verification:** A formal process requires secondary verification (e.g., via telephone) for all invoice changes or urgent payment requests.

2. Credential Hygiene & Isolation

- ☐ **Password Management:** Staff utilise enterprise password managers (e.g., Bitwarden, 1Password) to eliminate manual entry and storage.
- ☐ **Credential Separation:** A strict policy prohibits the reuse of passwords between professional and personal accounts.
- ☐ **Entropy Standards:** Passwords are generated using length-based complexity (e.g., three random words) rather than short, complex strings.

3. Vulnerability Management

- ☐ **Automated Patching:** Operating systems (Windows/macOS), web browsers, and mobile devices are configured to update automatically.
- ☐ **Legacy Software Removal:** Software that has reached End-of-Life (EoL) and no longer receives security updates has been decommissioned.
- ☐ **Restart Compliance:** Devices are restarted at least weekly to ensure critical security patches are fully applied.

4. Network Integrity & Remote Access

- ☐ **VPN Utilisation:** A Virtual Private Network (VPN) is mandatory when connecting to public or unsecured Wi-Fi networks.
- ☐ **Network Segmentation:** Visitors and personal devices are restricted to a "Guest" network, isolated from corporate resources.
- ☐ **Default Configuration:** Manufacturer default passwords on network infrastructure (routers/switches) have been changed.

5. Endpoint Protection

- ☐ **Active Defence:** Antivirus/Anti-malware solutions are active, real-time scanning is enabled, and cannot be disabled by standard users.
- ☐ **Script Control:** Microsoft Office macros are disabled by default for all files originating from the internet.
- ☐ **Application Allow-listing:** Staff are restricted to installing software exclusively from approved official repositories.

6. Generative AI Governance

- ☐ **Data Classification:** A policy clearly defines which data tiers (e.g., Public vs. Confidential) are permissible for input into AI tools.
- ☐ **Training Opt-Out:** Corporate settings are configured to prevent input data from being used to train public models.
- ☐ **Human-in-the-Loop:** A mandatory review process is in place to verify AI-generated content for accuracy and hallucinations prior to publication.

7. Business Continuity & Disaster Recovery

- ☐ **3-2-1 Backup Strategy:** We maintain three copies of data, on two different media types, with one copy stored offsite.
- ☐ **Immutable Backups:** At least one backup set is air-gapped (offline) or immutable to prevent encryption by ransomware.
- ☐ **Restoration Testing:** A disaster recovery drill has been successfully conducted within the last six months.

8. Physical Security & Culture

- ☐ **Unattended Access:** Workstations are configured to lock automatically after a short period (e.g., 5 minutes) of inactivity.
- ☐ **Asset Protection:** Sensitive physical documents are secured in locked storage when not in use.
- ☐ **Just Culture:** The organisation fosters a "no-blame" reporting culture to encourage disclosure of potential errors and recognised poor practice.

Essential Resources & Toolkits

- **NCSC Small Business Guide** (nsc.gov.uk/collection/small-business-guide): The National Cyber Security Centre's definitive guidance for SMEs, covering the core principles of cyber hygiene.
- **Cyber Essentials Information** (iasme.co.uk/cyber-essentials/): The UK government-backed certification scheme. This checklist provides the foundation for achieving certification.
- **North East Business Resilience Centre** (nebrcentreguardance.com): A police-led non-profit providing free membership and affordable security advice for North East organisations.
- **CyberNorth** (cybernorth.biz): The strategic cluster for the North East cyber security ecosystem, connecting businesses with local experts and events.
- **Action Fraud** (actionfraud.police.uk): The UK's national fraud and cyber crime reporting centre. The primary channel for reporting criminal cyber incidents.
- **Have I Been Pwned?** (haveibeenpwned.com): A resource to cross-reference email addresses and passwords against known historical data breaches.